LLM による SSVC 運用自動化に向けた検討
—SSVC 決定点の機械的予測と LLM による予測の比較—

阿部 一真 [1,*]　桑名 栄二 [1]

概要：脆弱性管理の現場では，年間数万件の CVE に対する優先順位付けが求められるが，SSVC に基づく判断は人手に依存しており，自動化の需要が高い．Al Haddad ら（2025）は LLM による SSVC 決定点予測を体系的に評価したが，報告された重み付き F1 スコアは，実際の CVE 全体とは異なるクラス構成の標本に基づいて算出されたものであった．本研究ではまず，先行研究の公開データに基づいて混同行列を再構成し，母集団比率に事後層化して精度を再評価した．その結果，Exploitation および Automatable の両決定点で，常に多数派クラスを出力する「自明な予測器」を下回る正答率であることが明らかとなった．次に，各決定点の機械的な予測可能性を検証し，Exploitation の"active"は KEV カタログとの照合で完全に一致すること，Automatable と Technical Impact は CVSS 基本評価基準に基づく判定ルールにより 95%を超える正答率で導出可能であることを示した．さらに Claude Sonnet 5 による予測実験を行い，enriched 条件では"active"の精度向上と"public_poc"の精度低下が相殺されることを確認した．以上の結果から，SSVC の運用自動化には，機械的に予測可能な決定点，LLM による予測が有効な決定点，組織固有の判断を要する決定点を分離して処理する方法が有効であることを示す．

キーワード：LLM（大規模言語モデル），脆弱性管理，SSVC，脆弱性トリアージ

LLM-based SSVC Automation: Mechanical Determinability vs. LLM in SSVC Decision Point Prediction

Kazuma Abe[1, *]　Eiji Kuwana[1]

Abstract: Vulnerability prioritization is a critical challenge in modern security operations, and the manual nature of SSVC-based assessment has created strong demand for automation. Al Haddad et al. (2025) systematically evaluated LLM-driven prediction of SSVC decision points; however, the weighted F1 scores they reported were computed on a sample whose class composition differs from that of the overall CVE population.
We first reconstructed confusion matrices from the data published by the prior study and re-evaluated accuracy under post-stratification to population class proportions. Under this evaluation, the Exploitation and Automatable decision points fall below a trivial predictor that always outputs the majority class. We then examined the mechanical determinability of each decision point and found that an Exploitation value of "active" corresponds exactly to KEV catalog inclusion, while Automatable and Technical Impact can be derived from CVSS base metrics with accuracy exceeding 95%. Prediction experiments with Claude Sonnet 5 further showed that, under an enriched input condition, gains for "active" are cancelled out by losses for "public_poc". These findings indicate that effective SSVC automation calls for separating decision points into those determinable mechanically, those where LLM assistance is effective, and those requiring organization-specific judgment.

Keywords: Large Language Models, Vulnerability Management, SSVC, Vulnerability Triage

1. はじめに

ソフトウェアの脆弱性は増加を続けており，2025 年には過去最高となる約 4.2 万件の CVE が米国 NIST の精査対象となった[1]．こうした状況を背景に，近年，全ての脆弱性に一律に対応するのではなく，リスクに応じて優先度を付け，優先順位の高い脆弱性から対応する方針への移行が進みつつある．

米国 CISA は 2026 年 6 月に BOD 26-04: リスクに基づくセキュリティ更新の優先順位付け[2]を発行し，米国の各連邦機関に対して，脆弱性のリスクを評価し，そのリスクに応じた期間内に是正措置を実施することを求めている．

しかし，企業のセキュリティ担当者は技術的な判断基準のみならず，自社の事業特性やシステムごとの個別事情を考慮して対応の優先順位付け（トリアージ）を行うことが求められる．これまで複数の脆弱性トリアージ手法が利用されてきたが，その多くは技術的な評価基準として活用されるにとどまっており，企業やシステムごとの文脈（コンテキスト）を十分に考慮できない点で課題があった．

そこで，コンテキストを考慮し，説明可能性と拡張性（カスタマイズ性）を重視した決定木ベースのトリアージ手法として SSVC フレームワーク[3]が提唱されている．

さらに，近年，大規模言語モデル（LLM）による SSVC 運用の自動化が試みられている[4][5][6]．具体的には，

1 情報セキュリティ大学院大学
Institute of Information Security

* mgs265502@iisec.ac.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

様々な情報を LLM に入力して，LLM に決定点（分岐点）の判断を行わせようとする取り組みである．しかし，複数ある決定点のどこで LLM を用いるのが有効か，LLM にどのような情報をインプットすることで判断精度が向上するかについて，実用的なアーキテクチャを構築する上で十分に明らかになっていない．

本研究では，SSVC の各決定点における判断を，公開情報からどの程度機械的に予測できるかを定量化し，機械的に予測しうる決定点とそうでない決定点を明らかにする．その上で，LLM の活用が有効な決定点を特定する．

2. 背景

2.1 脆弱性トリアージ（優先順位付け）の必要性

公開された脆弱性に対する優先順位付けは，従来からサイバーセキュリティ領域における重要な課題である．様々な製品ベンダーから発表される脆弱性情報を確認し，自組織のソフトウェアに関連する脆弱性かどうかを精査する必要がある．さらに，パッチの適用やソフトウェアのバージョンアップを検討する必要にも迫られる．これらの作業は日常的に発生する上，確認・精査に十分な対応リソースを確保できないことも多い．そのため，何らかの形で対応要否の判断や優先順位付けを行うことで，対応すべきスコープを絞り込む必要がある．

2.2 SSVC と BOD 26-04 との対応関係

前節に示した課題を解決するために提案された SSVC は，ステークホルダー毎に異なるカスタマイズ可能な決定木を用いるフレームワークである．「システム露出度」のような技術的評価だけでなく，「組織のミッションへの影響」「安全性・人的影響」など事業観点での評価も含む複数の決定点（判断指標）からなり，最終的に「即時修正」「延期」など具体的なアクションが導出される構造のモデルである．

BOD 26-04 では，脆弱性トリアージにおいて「具体的なアクションを規定する」という考え方をより詳細化し，4 つの判断指標によって判定された 16 通りの結果に基づき，具体的な是正期間を定めた．BOD 26-04 で用いられる KEV カタログへの掲載状況・攻撃の自動化可能性・技術的影響はいずれも公開されており，資産の外部公開状況については各政府機関が自組織の資産状況を客観的に判定する．

3. 関連研究

3.1 脆弱性トリアージ手法に関する研究

サイバーセキュリティ領域では様々な脆弱性トリアージ手法が用いられてきた．代表的なものとして CVSS, EPSS，KEV カタログ，SSVC などがある．CVSS は 2005 年に米 NIAC が研究・公開した手法で，現在に至るまで広く使われているが，その分，課題も多く指摘されている[7][8]．EPSS[9]は，各脆弱性の悪用可能性を予測する指標で，日次でスコアが変化するためトレンドを把握できる点に特長がある．また，CVSS の課題を補完する方法として，CVSS と EPSS や KEV を組み合わせる手法[10]や，攻撃者観点の指標を追加することで CVSS を補完する手法[11]も提案されている．しかし，複数のトリアージ手法を組み合わせて活用する手法に対しては，各手法の評価結果が必ずしも一致しないという課題が指摘されている[12].

3.2 SSVC に関する研究

前節に示した技術的側面に焦点を当てた評価指標が，組織・企業の個別事情（コンテキスト）を考慮できない問題を解決するため，2009 年に VRDA フレームワークが提唱され[13]，それを発展させる形で，2021 年に SSVC が提唱されたが[3]，SSVC にも運用上の課題が指摘されている．

まず，SSVC の各決定点で正しい判断を下すためには，自組織の資産情報を正確かつ網羅的に把握している必要があるが，実態として十分な情報を集約し管理できている組織は多くない[14]．また，SSVC の基本的な決定木モデルに含まれる「悪用状況（Exploitation）」を適切に判断するためには，脅威インテリジェンスを継続的に収集する必要があるが，人的・金銭的リソースの両面から実現が難しいケースがほとんどである[15]．その他，CVSS や EPSS に慣れている現場担当者にとって，定量的な評価が出力されないことへの心理的抵抗も普及の障害となっている[3].

3.3 LLM を用いた SSVC 運用の自動化に関する研究

SSVC の問題を解決するため，近年，LLM を活用することで SSVC の運用を自動化する研究が行われており，例えば Al Haddad らは，汎用 LLM が SSVC の各決定点および最終出力をどの程度正確に予測できるかについて，体系的に実験・評価した一連の研究を報告している[4][5][6].

Al Haddad らの最初の研究は，4 種の汎用 LLM と 12 種のプロンプト手法を用いて，ランダムに抽出した 384 件の CVE を対象とした SSVC による脆弱性トリアージ実験である[4]．同実験では，Vulnrichment[ ]に収録されている各 CVE の SSVC によるトリアージ結果を正解データとして，LLM が予測した決定点・最終出力と照らし合わせることで，LLM の予測精度を評価した．LLM による SSVC 決定点の予測精度（重み付き F1 スコア）は，最大 0.79 であったが，全ての LLM で偽陽性が多く出力されており，SSVC の運用を完全に自動化するのは難しいと結論づけられた．続いて Al Haddad らは，LLM のデータ汚染仮説[a]をもとに，それぞれの LLM が，Knowledge Cutoff Date

a) プロンプト経由で LLM にインプットする情報以外に，事前に脆弱性に関する情報を学習していることが，LLM の予測精度に影響しているのではないか，という仮説

© 2026 Information Processing Society of Japan

(KCD)[b]前に公開された脆弱性と KCD 後に公開された脆弱性のどちらに対して，SSVC の予測を正しく行えるのか，それはなぜか，を研究した[5]．その結果，KCD 後に公開された脆弱性の方が高い精度で SSVC 決定点を予測できることが明らかになった．研究ではその理由として，KCD 前に学習された古いデータや矛盾した情報が，LLM による推論を妨害していると考察している．

さらに Al Haddad らは，脆弱性情報のデータ詳細度が LLM の予測精度に与える影響を確かめるため，脆弱性ごとのデータ詳細度を 3 段階に分け，それぞれのグループで LLM の予測精度に違いが出るかを検証した[6]．同研究では，データ詳細度が高いグループと低いグループとの間に予測精度の差はあったが，データ詳細度が低いグループでも一定の精度を維持できることが明らかになった．

なお，LLM の出力が非決定論的（確率論的）であることから，一般的に LLM を利用したシステムの評価においては複数回の試行を行うことが適切であり[16][17]，Al Haddad らの 3 件の研究でも，条件ごとに 3 回の試行を行い，その結果をもとに算出した重み付き F1 スコアを主要な評価指標として報告している．

3.4 本研究の位置づけ

本研究では，Al Haddad らの先行研究を参考にしながら，最新の LLM を用いて SSVC 決定点の予測を試みるものである．実験手法や評価の枠組みは先行研究を踏襲しつつ，先行研究の手法や枠組みを拡張・変更した．具体的には，CVE のサンプリング手法，入力データ，具体的なプロンプト，使用 LLM の点で異なる手法を用いた．詳細は第 6 章で述べる．

本研究の独自性は，SSVC 決定点の機械的な予測可能性を検証することにある．

4. 先行研究結果の再分析

4.1 再分析の動機

前述の通り，Al Haddad らの先行研究では LLM の予測精度を評価するため，主に重み付き F1 スコア（Weighted F1-score）が利用されている．

一方で，正解データのクラス比率に不均衡が著しい分類タスクにおいて，重み付き F1 スコアは各クラスのサンプル数に応じた加重平均を行うため，多数派クラスの結果を過剰に反映する懸念がある．そのため，混同行列全体を均衡に評価できる Matthews 相関係数（MCC）[c]などの指標を併用することが推奨されている[18]．実際，Al Haddad らの研究データ[19]には MCC の値が含まれているが，各論文内では言及・評価されていない．

そこで本研究では，先行研究の結果を再評価するため，Al Haddad らが公開している研究データ（特に，全クエリに対する応答データ）から混同行列を再構成し，実験結果の内訳を検証した．

4.2 再分析の手法

再分析には，Al Haddad らが公開したデータのうち，165,888 件の全クエリに対して LLM が応答した結果（SSVC の決定点予測）を用いた．同様に Al Haddad らが公開している評価用スクリプトを解析し，試行ごと（クエリに対する応答ごと）に重み付き F1 スコアを算出した上で，条件ごとに行った 3 試行の調和平均を計算する手法を採用した．再分析の結果は付録 A に示す．

4.3 再現性の検証

再構成した値と先行研究の集計値を比較・照合したところ，4 種の LLM と 12 種のプロンプト手法を組み合わせて 4 つの決定点を予測した全 192 条件のうち，144 条件で重み付き F1 スコアが完全に一致した．一部，一致しなかった箇所は，Exploitation 決定点の正解値が空である 3 件の CVE の扱いに起因する相違であると考えられる[d]．なお，この相違は，混同行列から直接導かれる本研究の再分析結果および結論には影響しないと考えられる．

4.4 SSVC 決定点の予測精度に関する再評価

先行研究[4]が「最も高い予測精度」と報告したのは，Gemini Flash 1.5 に対して CoT（Chain of Thought[20]）の手法でプロンプトを入力した場合であり，Exploitation 決定点の予測精度は，重み付き F1 スコアで 0.79 であった．しかし，先行研究でサンプリングされた 384 件の CVE において，Vulnrichment に掲載されている Exploitation 決定点の値（正解データ）は，その 85.4%が“none”であり，その他の選択肢である“poc”と“active”が占める割合はそれぞれ 8.6%，5.2%であった．このように，データの偏りが著しい（不均衡な）サンプルに対して重み付き F1 スコアを計算すると，全体の予測精度が多数派クラスの予測精度に大きく影響されてしまい，必ずしも全体の予測精度を正しく測定できているとは言えない．

そこで，同一の組み合わせ（Gemini Flash 1.5×CoT）における Exploitation 決定点の予測精度を MCC で評価すると，MCC は 0.156 であり，予測結果と正解データの間の相関が極めて弱いことが示された．また，SSVC 決定点ごとに重み付き F1 スコアと MCC を見ると，MCC の最高値

b) 知識カットオフ日時／学習データの期限の略称．モデルが事前学習で取り込んだ情報の限界時点を指す

c) Matthews 相関係数（MCC）は機械学習の二値分類（または多クラス分類）モデルの性能を評価するための指標の一つ．予測結果と実際の正解データの間にどれくらいの相関があるかを，-1 から +1 の範囲の「相関係数」として算出する．係数が 0.0 であることは，完全にランダムな予測であることを表し，+1.0 に近づくほど正確に予測できていることを，-1.0 に近づくほど予測が正反対の結果になっていることを表す．一般に（絶対値で）0.0～0.2 で無相関，0.2～0.4 で弱い相関，0.4～0.7 で中程度の相関，0.7 以上で強い相関とみなす．

d) 先行研究と関連して公開されている各種データ・スクリプトからは，空の値をどのように処理しているのか判別できなかった．

© 2026 Information Processing Society of Japan

が 0.2 を超えているのは Technical Impact 決定点のみであり，その他の決定点ではいずれの LLM×プロンプトの組み合わせでも，MCC は 0.2 未満であり，相関が極めて弱いことが示された（付録 A）．

さらに，先行研究のサンプルにおける決定点比率が，CVE 全体の決定点比率とは異なることに注目し，実運用環境を想定した性能を再評価した．

例えば，先行研究において Exploitation 決定点における“none”，“poc”，“active”がサンプル全体に占める割合はそれぞれ 85.4%，8.6%，5.2%であったが，母集団，すなわち CVE 全体[e]における比率は，それぞれ 74.8%，24.3%，0.9%であった．Al Haddad らは決定点比率に基づいて（その比率が母集団と同じになるように）サンプリングする手法を用いておらず，比率に差異が生じている．

そこで，クラス条件付きの再現率・誤検出率（いずれも，重み付き F1 スコアの計算に用いる値）はクラス比率に依存しないことを利用し，母集団比率に基づいて事後層化[f]することで，全ての CVE を扱う実運用環境を想定した性能を測定できると考え，検証を行った（付録 B）．

Exploitation 決定点では，全件を“none”と予測する「自明な予測器」を下回る正答率であり，重み付き F1 スコアも「自明な予測器」をわずかに上回る程度であった．また Automatable 決定点でも，全件を“no”と予測する「自明な予測器」を下回る正答率であり，重み付き F1 スコアにもほとんど差がなかった．

一方で Technical Impact 決定点では，正答率と重み付き F1 スコアの両方で，先行研究は「自明な予測器」を上回る予測精度を示した．

以上の再分析結果から，先行研究が報告した予測精度は，MCC の観点・重み付き F1 スコアの観点の両面から，低い精度にとどまっていることが分かった．特に，Exploitation 決定点・Automatable 決定点の重み付き F1 スコアについては，実運用環境において「自明な予測器」の予測精度を下回ると推定された．

Al Haddad らも先行研究[4]の中で，実運用に足る精度ではないと述べている．続く発展研究[5][6]でも，入力データの詳細度や，CVE 公開時期と LLM の KCD との関係にいくらか影響することが示されているが，LLM の性能が予測精度に与える影響については明らかになっていない．

5. SSVC 決定点の機械的予測

5.1 検証の目的と枠組み

先行研究とその再分析結果から，LLM による SSVC 決定点の予測は困難である可能性が示された．そこで LLM による確率論的なアプローチではなく，公開情報に基づく決定論的なアプローチによって SSVC 決定点を予測できるか，また，可能である場合にどの程度の精度で予測できるか，という新たな問いを設定した．

本章では，これらの新たな問いを検証するため，SSVC の各決定点を公開情報から機械的に予測可能であるか，および，どの程度の精度で予測可能かについて検証する．

5.2 予測の対象となる決定点と，それぞれの検証結果

SSVC における 4 つの決定点について，それぞれ機械的に高精度な予測が可能かどうか，その手法はどのようなものかを検証した．

5.2.1 Exploitation

SSVC における Exploitation は，脆弱性の悪用状況を評価する決定点であり，その値は“active”“public_poc[g]”“none”のいずれかである[21]．CISA が Vulnrichment のリポジトリで公開しているフローチャート[**エラー! ブックマークが定義されていません。**]によると，当該 CVE が KEV カタログに掲載された場合，SSVC の Exploitation 決定点に“active”を付与する仕組みになっている．検証のため，Vulnrichment から SSVC の値が記述されている CVE を抽出し，そのうち Exploitation 決定点に“active”が付与されている全 1,435 件の CVE を確認したところ，その全てが KEV カタログに掲載されていた．

このことから，Exploitation 決定点の値が“active”であるかどうかは，KEV カタログとの照合によって，機械的に正確な予測が可能であると考えられる．

一方，Exploitation 決定点の値が“active”でない場合に，“public_poc”または“none”のどちらに該当するかを機械的に正確に予測する方法は見いだせなかった．

CISA が公開している SSVC ガイドでは，Exploitation 決定点を判定するために Metasploit や ExploitDB 等の脅威インテリジェンス情報をソースとして，公開された PoC の存在有無を確認する方法が示されている．しかし，SSVC 値が付与されている Vulnrichment 内の CVE で，Exploitation 決定点に“public_poc”が付与されている CVE のうち，Metasploit と ExploitDB に掲載されていた（PoC が公開されていると判別できる）CVE は約 1.1%であった．これは，全体の約 1.1%しか機械的に正確な予測ができないことを意味しており，実運用上有効な手段であるとは言えない．

5.2.2 Automatable

SSVC における Automatable は，サイバー攻撃の容易さと速度を表す決定点であり，その値は“yes”または“no”のいずれかである[21].

e) ここでは，先行研究の正解データとなっている Vulnrichment に記載の CVE データ全体をいう．

f) 先行研究の決定点比率が母集団の決定点比率と同じになるように，集計時に再度重み付けして計算する手法．サンプル数を削減せずに集計ができる手法で，事後層化（post-stratification）とも呼ばれる．

g)先行研究[4]の表記に合わせる形で第 4 章では単に“poc”と記述しているが，“poc”と“public_poc”は同じクラスを意味している．

© 2026 Information Processing Society of Japan

Automatable 決定点の機械的予測には，CVSS の基本評価基準[22]を用いることを考えた．CVSS は，様々な技術的観点（ベクトル）を組み合わせて脆弱性の深刻度をスコアリングする手法であり，Vulnrichment では各 CVE の CVSS スコアおよび各ベクトルの値（技術的観点からの評価結果）が公開されている．それらのうち，サイバー攻撃の容易さ・速度と関連する 4 つの指標，すなわち攻撃元区分（AV）・攻撃条件の複雑さ（AC）・必要な特権レベル（PR）・ユーザ関与の必要性（UI）を組み合わせることで，Automatable の値を機械的に予測する方法を検討した．具体的には，複数の指標とその値を組み合わせた判定ルールを作成し，それぞれの判定ルールの出力と正解データと突合することで，予測精度を測定した．特に精度の高かった判定ルールと予測精度を付録 C に示す．

Automatable 決定点では，4 つの指標を組み合わせることで機械的に高精度な予測を行うことができた．付録 C に掲載した判定ルールの正答率は最も高いもので 95%を超えており，実用上十分な性能であると考えられる．

5.2.3 Technical Impact

SSVC における Technical Impact は，その脆弱性が悪用された場合の技術的影響を意味する決定点であり，その値は“partial”または“total”のいずれかである[21]．

Technical Impact 決定点の機械的予測にも，Automatable 決定点と同様，CVSS の基本評価基準を用いた判定ルールを作成する方法を考えた．ただし Automatable 決定点とは異なり，サイバー攻撃の技術的影響に関連する 3 つの指標，すなわち機密性への影響（VC）・完全性への影響（VI）・可用性への影響（VA）を組み合わせる判定ルールを検討し，それぞれの判定ルールの予測精度を測定した．特に精度の高かった判定ルールを付録 D に示す．

Technical Impact 決定点では，3 つの指標を組み合わせることで機械的に高い精度の予測を行うことができた．付録 D に掲載した判定ルールの正答率は 95%を超えており，実用上十分な性能であると考えられる．

5.2.4 Mission & Wellbeing

SSVC における Mission & Wellbeing は，組織のミッションへの影響と幸福[h]への影響を意味する決定点であり，その値は Mission Prevalence と Public Well-Being Impact がそれぞれもつ 3 つの値の組み合わせによって，“high”“medium”“low”に分類される[21]．

しかし，この決定点の正解データが Vulnrichment 上に存在しないこと，そもそも機械的に予測できる性質の決定点でないことから，本検証の対象からは除外した．

5.3 予測結果の分析

検証結果を踏まえ，機械的に高精度な予測が可能な決定点・困難な決定点について，それぞれ述べる．

5.3.1 機械的に高精度な予測が可能な決定点

検証結果から，SSVC にある 4 つの決定点のうち，Automatable 決定点と Technical Impact 決定点についてはそれぞれ機械的に高精度な予測ができ，Exploitation 決定点については“active”なのかそれ以外なのかを機械的に高精度な予測ができることが明らかになった．

また，Exploitation 決定点の値が“active”であることは，評価対象となった CVE が KEV カタログに掲載されているかどうかと 100%一致しており，SSVC 決定点を LLM で予測する際の精度評価において，LLM の推論能力を測る対象として適していないことを示唆している．

5.3.2 機械的に高精度な予測が困難な決定点

Exploitation 決定点における“active”以外の 2 値，すなわち“public_poc”と“none”の予測（分類）については，本検証の結果を見る限り，機械的な予測が困難であると考えられる．CISA の SSVC ガイドでも“public_poc”かどうかを判断するための基準として，(1) Metasploit や ExploitDB などのウェブサイトに典型的な公開 PoC が存在するかどうか，(2) その脆弱性について悪用方法が周知されているかどうか，を挙げている．しかし (1) は前述の通り実運用で信頼し得る情報ソースとは言い難く，(2) に関しても情報収集対象が広範に及ぶため運用負荷が課題となる．

また，そもそも正解データが存在しない，という理由で未検証の Mission & Wellbeing 決定点についても，その定義からして，機械的な予測は難しいものと考える．

6. LLM を用いた SSVC 決定点の予測実験

6.1 実験の目的

第 4 章の再分析と，第 5 章の検証結果を踏まえ，以下の 2 つの問いを検証することを目的として実験を行った．

1. 先行研究を参考に，最新の LLM を用いて SSVC 決定点を予測した場合，予測精度は向上するか？
2. 機械的予測が困難な SSVC 決定点予測（特に，Exploitation 決定点における“public_poc”の予測）は，最新の LLM によって可能になるか？

6.2 実験の枠組み

6.2.1 LLM への入力情報

本実験では，Vulnrichment に記載されている各 CVE に関する技術的説明文のみを入力情報とした baseline 条件と，それに加えて KEV カタログ記載有無・ExploitDB 等への掲載有無の情報を付加した enriched 条件の，2 つの入力条件を用いた．前述の通り，KEV カタログ掲載有無の情報は，Exploitation 決定点の値が“active”であるかどうかを予測するための重要な情報であり，この情報の有無が予測精度の差を生むかどうか，検証するためである．

h) SSVC では，疾病対策センター（CDC）が提唱する，身体的，社会的，感情的，心理的な健康を含む包括的な幸福の定義を採用している．

© 2026 Information Processing Society of Japan

6.2.2 利用する LLM とプロンプト

本実験では，最新の LLM として Claude Sonnet 5 を利用した[i]．また，先行研究で用いられた 12 種のプロンプト手法から 4 手法を選抜して利用した．

プロンプト手法は，まず，先行研究[4]が述べている「Exemplar（具体例）を含むプロンプトが，そうでないプロンプトよりもおおむね優れたパフォーマンスを発揮した」という分析結果に基づき，Exemplar の有無が異なるプロンプト手法 3 種（ZS, FS, FSwE）を選抜した．さらに，複数の LLM との組み合わせで総合的に高い予測精度を発揮したプロンプト手法 1 種（CoT）を選抜した．

6.2.3 サンプリング

本実験では，Vulnrichment に掲載されている CVE から計 384 件のサンプルを抽出した[j]．ただし，前述の通りクラス構成の違いが評価結果を大きく左右すること，本実験では Exploitation 決定点について詳細に検証を行うことから，Exploitation 決定点が異なる 3 クラス（active, public_poc, none）のサンプル数が同数となるよう，それぞれ 128 件を抽出して利用した[k].

6.2.4 評価対象

本実験では，Vulnrichment に正解データが存在する SSVC の 3 つの決定点：Exploitation，Automatable，Technical Impact それぞれの値について LLM を用いた予測を行い，Vulnrichment に記載されている値と突合した結果を集計することで予測精度を評価した．

なお，Mission & Wellbeing 決定点は Vulnrichment 上に正解データが存在しないため，評価対象外とした．

6.2.5 評価指標・評価方法

先行研究[4]を参考に，各指標は試行ごとに算出した後，3 回の試行の調和平均を取って評価値とした．

評価指標には，先行研究[4]の論文内で報告された重み付き F1 スコアに加え，母集団比率に重みづけし直した（事後層化した）MCC・正答率・重み付き F1 スコアを用いた．

また，常に多数派クラスを予測する「自明な予測器」を評価基準として，各手法が基準を上回るかを評価した．

6.3 実験結果

本研究における実験結果を，baseline 条件と enriched 条件のそれぞれについて示す．

6.3.1 baseline 条件

baseline 条件下での決定点別の予測精度を付録 E に示す．重み付き F1 スコア・正答率ともに，付録 B で示した先行研究[4]の予測精度を上回っており，MCC の値はいずれも中程度の相関を示していると言える．

また正答率については，常に多数派クラスの値を出力する「自明な予測器」の正答率とも比較した．baseline 条件では，Exploitation 決定点では 5.3pp，Technical Impact 決定点では 15.6pp，それぞれ「自明な予測器」の正答率を上回った．一方，Automatable 決定点では「自明な予測器」を 8.0pp 下回る正答率となった．

6.3.2 enriched 条件

enriched 条件下での決定点別の予測精度を付録 F に示す．enriched 条件では，baseline 条件の入力情報に KEV カタログ記載有無・ExploitDB 掲載有無の情報を付加して予測を行った．各決定点の指標を見ると，予測精度はほとんど変化しなかった．

6.4 実験結果の分析

本実験では，baseline 条件・enriched 条件の両方で，先行研究[4]を上回る予測精度が得られた．特に，クラス間の不均衡が著しいサンプルの分類タスクで用いられる MCC については，先行研究を大きく上回り[l]，中程度の相関を示す結果となった．先行研究とは複数の点で異なる手法を用いたため厳密な比較は難しいが，本実験の結果を踏まえ，最新の LLM を用いることで SSVC 決定点の予測精度が向上した可能性があると考える．

また，Exploitation 決定点における“public_poc”の予測においては，付録 G に示す通り，本実験の予測精度は先行研究を大きく上回る結果となった．

6.5 2 条件間で差がある“public_poc”の予測精度

Exploitation 決定点の予測精度をクラス別にみると，付録 G に示した通り“active”の予測精度が大きく上昇した一方，“public_poc”の予測精度は低下しており，両者の相殺によって Exploitation 決定点の精度指標が変化しなかったように見えていたことが分かる．

“public_poc”の予測について，enriched 条件では脅威インテリジェンス情報を追加したにもかかわらず，baseline 条件よりも予測精度が低下した．この原因を探るため，2 条件間における CVE ごとの予測結果の遷移を付録 H に示した．ここから，baseline 条件で“public_poc”と予測された CVE の約 46%が，enriched 条件で“none”と予測された（予測が変化した）ことが分かる．

本実験の enriched 条件では，“public_poc”と“none”に該当する CVE のいずれについても，LLM には「KEV 掲載なし」という同一の情報が渡されていた．これは，enriched 条件における LLM の予測課題が「その CVE は

---

i) 実験を行った時点では Claude Opus4.8 等の上位モデルも公開されていたが，コストパフォーマンスの観点から Claude Sonnet 5 を利用した．

j) 先行研究と同様，母集団に対して 95%の信頼区間，5%の許容誤差，および推定応答割合 50%に基づき，必要最小サンプル数を設定した．

k) 母集団の比率通りにサンプルを抽出すると，Exploitation 決定点の値が“none”である CVE がその多くを占めてしまうため，“active”や“public_poc”を正しく予測できるかどうかを十分に評価できない．

l) 先行研究[4]の公開データ[19]から再集計した MCC（母集団比率で事後層化した値）は，Exploitation 決定点で 0.0561，Automatable 決定点では 0.0582，Technical Impact 決定点では 0.230 であった．

© 2026 Information Processing Society of Japan

“active”か，否か」という二値分類に置き換わったことを示唆しており，付録 H で示した遷移とも整合する．LLM の入力情報として「KEV カタログ等に当該 CVE の情報がない」とプロンプト内に記述したことが「脆弱性に悪用の可能性がない」と解釈され，enriched 条件で LLM が“public_poc”と“none”を同一視してしまったと解釈できる．

なお，enriched 条件で“active”の予測精度が向上したことは，第 5 章で示した通り，KEV カタログ掲載有無がそのまま正解ラベルの判断根拠になったことによる，必然的な精度向上だったと言える．

7. 考察

7.1 SSVC 決定点の予測手法

第 4 章から第 6 章の実験結果は，SSVC の運用において「機械的に高精度な予測ができる決定点」と「機械的に高精度な予測が難しい決定点」に区分できることを示している．

7.1.1 SSVC 決定点の機械的予測

第 5 章と第 6 章の結果を踏まえ，SSVC の運用において機械的に高精度な予測ができる決定点は，Exploitation 決定点（“active”のみ），Automatable 決定点，Technical Impact 決定点である．Exploitation 決定点は KEV カタログとの照合により完全に一致し，Automatable・Technical Impact 決定点は判定ルールにより 95%を超える正答率が得られており，運用上有効な水準にあると考える．

7.1.2 LLM を用いた SSVC 決定点予測

同様に第 5 章と第 6 章の結果を踏まえると，LLM による予測精度が機械的予測の精度を上回るのは，Exploitation 決定点における“public_poc”と“none”の識別のみであった．付録 G の通り，本研究の実験で到達した Exploitation 決定点の予測精度（重み付き F1 スコア）は，先行研究の予測精度を大きく上回っているが，“public_poc”の予測精度を見ると，実用段階にあるとは言い難い．

なお，LLM による決定点予測は，Technical Impact 決定点では「自明な予測器」の予測精度を上回ったが，機械的予測の精度を上回ることができなかった．また Automatable 決定点では「自明な予測器」の予測精度さえ上回ることができなかった．

ただし，第 6 章の結果からは，LLM 自体の性能向上により決定点の予測精度が向上する可能性も示唆されており，今後さらに性能が向上した LLM を利用することで，機械的な決定点の予測精度に近づくことも考えられる．

7.2 LLM による SSVC 運用自動化の課題

第 6 章で述べたように，LLM にどのようなプロンプトを入力するかによって，LLM の推論および予測結果に大きな影響を与えることが示唆された．LLM による SSVC 運用自動化を検討する上で，脅威インテリジェンス情報をどのように LLM に入力するかは、構造的な問題である．

第一に，各決定点のクラス定義（クラスの境界・判別基準）と入力情報の対応関係を事前に調査する必要がある．付加する情報が特定のクラスの予測を容易にする一方，他の複数のクラス間の予測を困難にする場合があることを考慮して，入力情報を設計しなければならない．

第二に，情報の欠如を明示的に記述する方式が及ぼす影響を考慮する必要がある．先行研究[4]でも本実験と同様の処理を行っており，著者らも，情報が掲載されていない場合にはプロンプト内に何も記述しない方が望ましい可能性について言及しているが，検証されていない．

第三に，この構造的問題は前節で示した LLM と機械的予測の役割分担の考え方を補強している．機械的に高精度な予測が可能な分類問題のために入力情報を付加することが，LLM が本来の性能を発揮し得る予測問題において，LLM の性能を低減させてしまう可能性がある．

8. 実験手法の課題と限界

8.1 Exploitation 決定点の“public_poc”を機械的な予測の可能性が未検証

Exploitation 決定点における“public_poc”の機械的予測の可否について，SSVC ガイド[21]が例示した ExploitDB および Metasploit のみを参照対象とし，掲載率が約 1.1%にとどまるため機械的予測は難しいと述べた．しかし，公開 PoC の参照先はこれらに限定されず，同種のリポジトリ等，他の情報源を参照先として利用することで，機械的予測の精度と実現性は，より高くなる可能性がある．

8.2 サンプリング手法・サンプル数

本研究の実験では，実運用上の利用可能性を検討するため，評価指標として，母集団比率に事後層化した重み付き F1 スコアを採用し，評価を行った．

一般に，母集団比率への事後層化処理は，予測器（今回でいう LLM）の予測性能が母集団全体とサンプル群で変化しない，という仮定を前提とする．しかし，母集団全体を対象に予測実験を行うことは困難であり，本研究において，この仮定は検証していない点に留意が必要である．

8.3 利用する LLM モデル

本研究の実験で予測精度を測定した LLM は 1 種のみであり，他の LLM でも同様の結果が得られるかどうかについては検証していない．したがって，今回の実験結果や考察が，LLM 一般に当てはまるものとは言えない点に留意されたい．

8.4 Mission & Wellbeing 指標の性質

Mission & Wellbeing 決定点については，組織や企業に固有の事情に基づく判断が必要であり，本研究の実験で正解データとした Vulnrichment にも当該決定点の値は記載されていない．事前に正解データが入手できない前提で，

© 2026 Information Processing Society of Japan

Mission & Wellbeing 決定点をどのように扱うのが妥当かについては未検証であり，これは Mission & Wellbeing 決定点のもつ性質による実験手法の限界であると考える．

8.5 LLM モデルのデータ汚染

前述の通り，先行研究[5]は LLM の KCD 前後で CVE を 2 つのクラスに分けて予測を行ったが，KCD 後（LLM が各 CVE について事前情報を学習していない場合）の方が予測精度は高かったと報告している．Al Haddad らはその原因がデータ汚染である可能性を示唆しながら，統計的に有意な水準には届いていないと述べている．本研究においても同様に，KCD がどのように予測精度に影響を及ぼすのかは，未検証である．

9. 今後に向けて

本研究でも検証した通り，機械的予測あるいは LLM による予測が運用上「完璧」なものになっているとは言い難く，従来の専門家による判断を支援する形で利用するのが望ましいと言える．

また，本研究では，先行研究と CISA の SSVC ガイドを参考に 4 つの決定点に言及したが，それ以外にも SSVC には複数の決定点がある．その他の決定木あるいは決定点についても研究されており[23]，組織・企業の脆弱性トリアージおよび対応についても，支援する枠組みを提案できる可能性がある．

今後は，本研究で明らかになった課題を解消しながら，先行研究の条件を厳密に再現した上で LLM のみを最新化する試みや，プロンプトへの情報入力手法の改善，本研究で示した実験手法の課題および限界の改善・解消に加え，どのような SSVC の決定木であれば LLM による運用自動化が可能なのか，等にアプローチしたい．

参考文献

[1] National Institute of Standards and Technology. NIST Updates NVD Operations to Address Record CVE Growth. NIST. 2026-04. https://www.nist.gov/news-events/news/2026/04/nist-updates-nvd-operations-address-record-cve-growth

[2] Cybersecurity and Infrastructure Security Agency. BOD 26-04: Prioritizing Security Updates Based on Risk. CISA. 2026. https://www.cisa.gov/news-events/directives/bod-26-04-prioritizing-security-updates-based-risk

[3] Spring, J. M., Householder, A. D., et al., Prioritizing Vulnerability Response: A Stakeholder-Specific Vulnerability Categorization (Version 2.0). Carnegie Mellon University, Software Engineering Institute, 2021, Technical Report SEI-2021-TR-019.

[4] Al Haddad, O., Ikram, M., et al., Prompting the Priorities: A First Look at Evaluating LLMs for Vulnerability Triage and Prioritization. arXiv. 2025, arXiv:2510.18508.

[5] Al Haddad, O., Ikram, M., et al., A Temporal Paradox in Software Vulnerability Prioritization: Why Do Large Language Models Perform Better Post-Knowledge Cutoff Date?. NDSS Symposium 2026, LAST-X Workshop. 2026.

[6] Al Haddad, O., Ikram, M., et al., Leveraging Sparse Intelligence: Large Language Models Can Provide Actionable Priorities From Limited Cyber Threat Data. 1st International Workshop on AI Safety and Security (AI-SS), EDCC 2026. 2026.

[7] Spring, J. M., Hatleback, E., et al., Towards Improving CVSS. Carnegie Mellon University, Software Engineering Institute, 2018, Technical Note.

[8] Wunder, J., Kurtz, A., et al., Shedding Light on CVSS Scoring Inconsistencies: A User-Centric Study on Evaluating Widespread Security Vulnerabilities. IEEE Symposium on Security and Privacy. 2024, p. 1102-1121.

[9] Jacobs, J., Romanosky, S., et al., Exploit Prediction Scoring System (EPSS). ACM Digital Threats: Research and Practice. 2021, vol. 2, no. 3, p. 1-17.

[10] Shimizu, N. and Hashimoto, M. Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization. arXiv. 2025, arXiv:2506.01220.

[11] Bulut, M. F., Adebayo, A., et al., Vulnerability Prioritization: An Offensive Security Approach. arXiv. 2022, arXiv:2206.11182.

[12] Koscinski, V., Nelson, M., et al., Conflicting Scores, Confusing Signals: An Empirical Study of Vulnerability Scoring Systems. ACM SIGSAC Conference on Computer and Communications Security. 2025, p. 1-16.

[13] Manion, A., Togashi, K., et al., Effectiveness of the Vulnerability Response Decision Assistance (VRDA) Framework. Carnegie Mellon University, Software Engineering Institute, 2009, Technical Report.

[14] Souppaya, M. and Scarfone, K. Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology. NIST Special Publication. 2022, no. 800-40r4.

[15] Chang, T.-S. and Hsu, H.-Y. Critical Resource Factors for Cyber Threat Intelligence Implementation in Enterprises. IEEE Transactions on Engineering Management. 2026, vol. 73.

[16] Cybersecurity and Infrastructure Security Agency. Vulnrichment: Enriching CVE Records with SSVC Decision Points. GitHub. 2024-. https://github.com/cisagov/vulnrichment/tree/develop

[17] Song, Y., Wang, G., et al., The Good, The Bad, and The Greedy: Evaluation of LLMs Should Not Ignore Non-Determinism. arXiv. 2024, arXiv:2407.10457.

[18] Alvarado Gonzalez, M. A., Bruno Hernandez, M., et al., Do Repetitions Matter? Strengthening Reliability in LLM Evaluations. arXiv. 2025, arXiv:2509.24086.

[19] Boughorbel, S., Jarray, F., et al., Optimal Classifier for Imbalanced Data Using Matthews Correlation Coefficient Metric. PLoS ONE. 2017, vol. 12, no. 6, p. e0177678.

[20] Al Haddad, O., Ikram, M., et al., LLM-Vulnerability-Prioritization/Prompting-The-Priorities. GitHub. 2025-. https://github.com/LLM-Vulnerability-Prioritization/Prompting-The-Priorities

[21] White, J., Fu, Q., et al., A prompt pattern catalog to enhance prompt engineering with ChatGPT. arXiv. 2023. arXiv:2302.11382.

[22] Cybersecurity and Infrastructure Security Agency. CISA Stakeholder-Specific Vulnerability Categorization Guide. CISA. 2022-11. https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf

[23] Forum of Incident Response and Security Teams. Common Vulnerability Scoring System Version 4.0: Specification Document. FIRST. 2023-11-01. https://www.first.org/cvss/v4.0/specification-document

[24] Tsuji, D., Ueki, Y., et al., Automating SSVC: A Worst-Case Scenario Approach for Evaluating Human Impact of Vulnerabilities. IEICE Communications Express. 2026, vol. 15, no. 5, p. 156-159.

© 2026 Information Processing Society of Japan

付録

付録 A　先行研究[4]のデータ[19]を再集計した予測精度

各決定点の重み付き F1 スコアの上位 3 件，MCC（Matthews 相関係数）の上位 3 件を抽出して以下に示す.
ただし，表中の PT は先行研究[4]内で提示されたプロンプト種別，wF1 は重み付き F1 スコアを，それぞれ表している.

表 1　Exploitation：重み付き F1 スコア（上位 3 件）
Table 1　Top 3 Prompting Techniques by Weighted F1-score for Exploitation.

順位	LLM	PT	wF1	MCC
1	Gemini Flash 1.5	CoT	0.779	0.156
2	Gemini Flash 1.5	FSwE	0.741	0.128
3	Gemini Flash 1.5	FS	0.701	0.083

表 2　Exploitation：MCC（上位 3 件）
Table 2　Top 3 Prompting Techniques by MCC for Exploitation.

順位	LLM	PT	wF1	MCC
1	Gemini Flash 1.5	CoT	0.779	0.156
2	ChatGPT 4o-mini	FSwE	0.582	0.139
3	Gemini Flash 1.5	FSwE	0.741	0.128

表 3　Automatable：重み付き F1 スコア（上位 3 件）
Table 3　Top 3 Prompting Techniques by Weighted F1-score for Automatable.

順位	LLM	PT	wF1	MCC
1	Gemini Flash 1.5	CoT	0.664	0.128
2	ChatGPT 4o-mini	FSwE	0.659	0.199
3	ChatGPT 4o-mini	CoT	0.654	0.158

表 4　Automatable：MCC（上位 3 件）
Table 4　Top 3 Prompting Techniques by MCC for Automatable.

順位	LLM	PT	wF1	MCC
1	ChatGPT 4o-mini	FSwE	0.659	0.199
2	Gemini Flash 1.5	FSwE	0.614	0.192
3	ChatGPT 4o-mini	FS	0.618	0.172

表 5　Technical Impact：重み付き F1 スコア（上位 3 件）
Table 5　Top 3 Prompting Techniques by Weighted F1-score for Technical Impact.

順位	LLM	PT	wF1	MCC
1	Gemini Flash 1.5	SR	0.650	0.335
2	Gemini Flash 1.5	PP	0.646	0.317
3	Gemini Flash 1.5	ZSCoT	0.645	0.318

表 6　Technical Impact：MCC（上位 3 件）
Table 6　Top 3 Prompting Techniques by MCC for Technical Impact.

順位	LLM	PT	wF1	MCC
1	Claude 3 Haiku	FSwE	0.644	0.345
2	Gemini Flash 1.5	SR	0.650	0.335
3	ChatGPT 4o-mini	MP	0.605	0.324

表 7　Mission & Wellbeing：重み付き F1 スコアおよび MCC（上位 3 件）
Table 7　Top 3 Prompting Techniques by Weighted F1-score and MCC for Mission & Wellbeing.

順位	LLM	PT	wF1	MCC
1	Gemini Flash 1.5	MP	0.432	0.155
2	Gemini Flash 1.5	SR	0.417	0.138
3	Gemini Flash 1.5	ZSCoT	0.407	0.125

*Mission & Wellbeing 決定点においては，重み付き F1 スコアの上位 3 件と MCC の上位 3 件における LLM と PT の組み合わせが同じだったため，同一の表で示す

© 2026 Information Processing Society of Japan

付録 B

表 8　先行研究と「自明な予測器」における SSVC 決定点の予測精度比較

Table 8　Prediction Accuracy of the Prior Study Compared with a Trivial Predictor.

	重み付き F1 スコア*		正答率*	
	先行研究**	自明な予測器	先行研究**	自明な予測器
Exploitation	0.675	0.640	68.9%	74.8%
Automatable	0.671	0.666	63.4%	76.7%
Technical Impact	0.710	0.543	74.7%	67.4%

*いずれも母集団比率で計算した値

**いずれも本研究内で再集計した値のうち，最高値を掲載

※なお，Mission & Wellbeing 決定点については，先行研究では機械的に各クラスの正解データが 33.3%となるように設計していたため，検証対象から除外している

付録 C

表 9　CVSS 基本評価基準を用いた判定ルールによる Automatable 決定点の予測結果

Table 9　Prediction of the Automatable Decision Point Using Rules Based on CVSS Base Metrics.

判定ルール*	**正答率****	**重み付き F1 スコア****
AV:N ∧ AC:L ∧ PR:N ∧ UI:N であれば Automatable: yes	95.6%	0.910
AC:L ∧ PR:N ∧ UI:N であれば Automatable: yes	94.3%	0.887
AV:N ∧ PR:N ∧ UI:N であれば Automatable: yes	92.8%	0.861

*ルール内の「∧」は AND 条件を表す

**いずれも母集団比率で計算した値

付録 D

表 10　CVSS 基本評価基準を用いた判定ルールによる Technical Impact 決定点の予測結果

Table 10　Prediction of the Technical Impact Decision Point Using Rules Based on CVSS Base Metrics.

判定ルール*	**正答率****	**重み付き F1 スコア****
VC:H ∧ VI:H であれば Technical Impact: total	95.4%	0.932
VC:H ∧ VI:H ∧ VA:H であれば Technical Impact: total	95.2%	0.924

* ルール内の「∧」は AND 条件を表す

**いずれも母集団比率で計算した値

付録 E

表 11　baseline 条件における決定点別の予測精度

Table 11　Prediction Accuracy per Decision Point under the baseline Condition.

決定点	**重み付き F1 スコア***	**MCC***	**正答率***
Exploitation	0.797	0.454	80.1%
Automatable	0.714	0.429	68.7%
Technical Impact	0.834	0.638	83.0%

*いずれも母集団比率で計算した値．複数のプロンプト手法を用いた予測結果のうち，MCC が最も高かったプロンプト手法の値を掲載

© 2026 Information Processing Society of Japan

付録 F

表 12　enriched 条件における決定点別の予測精度

Table 12　Prediction Accuracy per Decision Point under the enriched Condition.

決定点	重み付き F1 スコア*	MCC*	正答率*
Exploitation	0.784	0.471	81.9%
Automatable	0.701	0.428	67.4%
Technical Impact	0.830	0.632	82.5%

*いずれも母集団比率で計算した値

付録 G

表 13　Exploitation 決定点のクラス別・条件別予測精度

Table 13　Prediction Accuracy for the Exploitation Decision Point by Class and Condition.

クラス	baseline 条件*	enriched 条件*	先行研究*
none	0.856	0.887	0.466
public_poc	0.567	0.429	0.176
active	0.758	1.000	0.031

*いずれも母集団比率で計算した重み付き F1 スコア.「先行研究」については，
いずれも本研究内で再集計した値のうち，最高値を掲載

付録 H

表 14　CVE 別・baseline 条件と enriched 条件での予測遷移

Table 14　Transition of Predictions between the Baseline and Enriched Conditions per CVE.

baseline＼enriched	active	public_poc	none	計
active	242	1	1	244
public_poc	55	142	166	363
none	37	2	687	726
unknown	12	0	10	22
計	346	145	864	1,355

*384CVE×4 プロンプト手法ごとの予測結果を、3 試行の最頻値で集計.
応答のパースエラー等により 181 件（11.8%）が欠損している

© 2026 Information Processing Society of Japan